Alias Equals Zone? Large-Scale and Stealthy Takeover of Domain Hosting Service via CNAME-Following Cross-Domain Verification

Content

Alias Equals Zone? Large-Scale and Stealthy Takeover of Domain Hosting Service via CNAME-Following Cross-Domain Verification

Ruixuan Li, *Tsinghua University;* Xingyu Zhao, *Zhejiang Gongshang University;* Yunyi Zhang and Baojun Liu, *Tsinghua University;* Jun Shao, *Zhejiang Gongshang University and Zhejiang Key Laboratory of Big Data and Future E-Commerce Technology*

CNAME records define alias relationships between domains and are widely used for service hosting and load balancing. We find that popular domain hosting providers misinterpret CNAME semantics during domain ownership verification. They accept DNS records after CNAME redirection as valid challenge tokens for alias domains, even though these domains do not configure any tokens. Based on this flaw, we propose ALIASLEAP, a novel domain takeover attack that enables hijacking hosting services of alias domains in CNAME chains. ALIASLEAP poses a serious threat in the real world: we identify four email and seven web hosting providers that are vulnerable, affecting over two million domains, including 200K in the Tranco Top 1M domain list. ALIASLEAP is highly stealthy because vulnerable CNAME chains are typically legitimate and long-lived: about half persist for more than 12 months, and up to 19,819 domains have been exposed for over 10 years. We propose mitigation strategies and responsibly disclose ALIASLEAP to 11 affected hosting providers, receiving confirmations from eight of them. We call on the Internet community to revisit the usage practices and capability boundaries of CNAME records.

Category:

Short Presentation

Open Access Media

USENIX is committed to Open Access to the research presented at our events. Papers and proceedings are freely available to everyone once the event begins. Any video, audio, and/or slides that are posted after the event are also free and open to everyone. Support USENIX and our commitment to Open Access.

[image: image] Li PDF